

Due-Diligence Report: repo_5

Self-audit passed — every finding this report gathered is cited below.

Verdict: 9/10 — Est. 20-36 engineer-hours to acquisition-ready

repo_5 (Pydantic) is an actively maintained Python validation library with MIT license and 0 vulnerable packages, though test execution failed due to unrecognized pytest benchmark arguments. Secret scan identified hardcoded password findings in production and doc files including docs\concepts\serialization.md, docs\examples\secrets.md, docs\examples\validators.md. Total remediation cost is estimated at 28 hours (range 20-36h).

Remediation Cost Estimate

Item	Hours	Basis
Rotate 20 hardcoded credential(s) found in production code	20	1h per finding (rotate + remove from code + wire to secrets manager)
Stand up a working automated test suite	8	Flat estimate — tests did not run successfully during audit

Total: 28 hours (range: 20-36h)

Heuristic estimate based on the stated per-item assumptions above, not a professional engineering quote. Presented as a range (20-36h) to avoid false precision. Does not include general code-quality improvements beyond the specific findings listed.

Risks

- Hardcoded credential / secret finding detected in non-test file docs\concepts\serialization.md.
Secret scan: file docs\concepts\serialization.md line 416 type Hardcoded value assigned to 'password' (low-entropy — not caught by randomness check) in_test_dir: false.
- Hardcoded credential / secret finding detected in non-test file docs\examples\secrets.md.
Secret scan: file docs\examples\secrets.md line 25 type Hardcoded value assigned to 'password' (low-entropy — not caught by randomness check) in_test_dir: false.
- Hardcoded credential / secret finding detected in non-test file docs\examples\validators.md.
Secret scan: file docs\examples\validators.md line 213 type Hardcoded value assigned to 'password' (low-entropy — not caught by randomness check) in_test_dir: false.
- Hardcoded credential / secret finding detected in non-test file docs\plugins\using.toml.
Secret scan: file docs\plugins\using.toml line 71 type High-entropy string (possible secret) in_test_dir: false.
- Hardcoded credential / secret finding detected in non-test file pydantic\types.py.
Secret scan: file pydantic\types.py line 1695 type Hardcoded value assigned to 'password' (low-entropy — not caught by randomness check) in_test_dir: false.
- Automated tests failed to run due to unrecognized test runner arguments.
Build/test evidence: tests_ran: false, error: unrecognized arguments: --benchmark-columns.

Strengths

- Highly active maintenance with recent commits and merges.

GitHub activity: days_since_last_push: 1, recent_merge_count_sampled: 18.

- MIT project license with no dependency license conflicts.

License check: project_license: {found: true, license: MIT}, conflicts: [].

License

Project license: **MIT**

Dependencies checked: 0, conflicts: 0, unknown license: 0

Ownership & Continuity Risk

100 contributor(s), top contributor: 23.8% of commits, last push: 1 days ago

Could Not Verify

- Dependency vulnerability scan details because packages_checked was 0.
- Container configuration because Dockerfile is absent.

Every claim above is backed by evidence in the full JSON report.